

WUXUAI Legal Operating System

Phase 2.2 – Rollen und Verantwortlichkeiten

Dokumentversion: 0.1

Rechtsraum: Österreich / Europäische Union

Dokumentstatus: Anwaltlich zu prüfender Entwurf

Plattformbetreiber: WUXUAI GmbH, Österreich, Gründung geplant

1. Zweck dieses Dokuments

Dieses Dokument legt die rechtlichen, organisatorischen und technischen Rollen innerhalb der WUXUAI-Plattform fest.

Es bildet die Grundlage für:

- die B2B-SaaS-AGB;
- den Auftragsverarbeitungsvertrag;
- die Datenschutzerklärungen;
- das Berechtigungskonzept;
- die Row-Level-Security-Regeln;
- die Audit- und Protokollierungsregeln;
- die Support- und Administrationsrechte;
- den Umgang mit Datenschutzanfragen;
- die Verantwortlichkeit bei Sicherheitsvorfällen;
- den späteren technischen Codex-Masterauftrag.

Die Zuordnung einer Partei als Verantwortlicher oder Auftragsverarbeiter richtet sich nicht allein nach der Vertragsbezeichnung, sondern nach der tatsächlichen Entscheidung darüber, zu welchem Zweck und mit welchen wesentlichen Mitteln personenbezogene Daten verarbeitet werden.

2. Grundmodell der Plattform

WUXUAI stellt Restaurants eine technische SaaS-Plattform zur Verfügung, mit der diese eigene Kundenbindungs- und Bonusprogramme betreiben können.

Das jeweilige Restaurant entscheidet insbesondere:

- ob es ein Bonusprogramm anbietet;
- welche Gäste teilnehmen dürfen;
- welche Punkte vergeben werden;
- nach welchen Regeln Punkte entstehen;
- welche Rewards angeboten werden;
- wann Rewards eingelöst werden können;
- wie lange Punkte oder Rewards gültig bleiben;

- welche Marketingkanäle verwendet werden;
- welche Inhalte an Gäste versendet werden;
- wann das Bonusprogramm geändert oder beendet wird.

WUXUAI stellt hierfür die technische Infrastruktur, Benutzeroberflächen, Datenbankfunktionen, Sicherheitsfunktionen und Administrationswerkzeuge bereit.

WUXUAI ist nicht Anbieter der Speisen, Getränke, Rabatte oder Rewards des Restaurants.

3. Rechtliche Hauptrollen

3.1 WUXUAI GmbH

Vertragliche Rolle

WUXUAI ist:

- Anbieter der SaaS-Plattform;
- Vertragspartner der teilnehmenden Restaurants;
- Betreiber der technischen Plattform;
- Lizenzgeber der Software;
- technischer Support- und Wartungsdienstleister.

WUXUAI ist nicht:

- Betreiber des jeweiligen Restaurantbetriebs;
- Verkäufer der vom Restaurant angebotenen Speisen oder Getränke;
- Schuldner der vom Restaurant zugesagten Rewards;
- Aussteller eines Zahlungsmittels;
- Betreiber einer zentralen Geldbörse;
- Vertragspartner des Gastes hinsichtlich der gastronomischen Leistung;
- Garant für die Einlösung einer Restaurantbelohnung.

Datenschutzrechtliche Rolle

WUXUAI nimmt abhängig von der jeweiligen Verarbeitung unterschiedliche Rollen ein.

A. WUXUAI als Auftragsverarbeiter

WUXUAI handelt grundsätzlich als Auftragsverarbeiter des Restaurants, soweit WUXUAI personenbezogene Daten von Gästen ausschließlich zur technischen Durchführung des vom Restaurant bestimmten Bonusprogramms verarbeitet.

Dies betrifft insbesondere:

- Verwaltung von Gastkonten innerhalb des Restaurantprogramms;
- Speicherung von Punkteständen;
- Speicherung von Punktebuchungen;
- Speicherung von Rewardansprüchen;

- Verarbeitung von Reward-Einlösungen;
- Speicherung restaurantbezogener Besuchshistorien;
- technische Zustellung restaurantseitig veranlasster Nachrichten;
- Bearbeitung restaurantseitig veranlasster Datenexporte;
- Bearbeitung restaurantseitig veranlasster Löschvorgänge;
- technische Protokollierung im Auftrag des Restaurants.

WUXUAI verarbeitet diese Daten grundsätzlich nur:

- auf dokumentierte Weisung des Restaurants;
- im Rahmen des SaaS-Vertrags;
- im Rahmen des Auftragsvertrags;
- soweit dies für Betrieb, Sicherheit und Vertragserfüllung erforderlich ist.

B. WUXUAI als eigenständig Verantwortlicher

WUXUAI ist eigenständig Verantwortlicher für Verarbeitungen, deren Zwecke und wesentliche Mittel WUXUAI selbst festlegt.

Dies betrifft insbesondere:

- Abschluss und Verwaltung des SaaS-Vertrags;
- Verwaltung der Restaurant-Owner-Konten;
- Abrechnung, Buchhaltung und Zahlungsverwaltung;
- Betrugs- und Missbrauchsprävention auf Plattformebene;
- IT-Sicherheitsüberwachung;
- eigene Supportkommunikation;
- gesetzlich erforderliche Unternehmensaufzeichnungen;
- Verwaltung eigener Website- und Vertragsanfragen;
- Nachweis der Zustimmung zu WUXUAI-eigenen Vertragsbedingungen;
- Schutz, Durchsetzung und Verteidigung eigener Rechtsansprüche;
- technische Plattformprotokolle, soweit WUXUAI deren Zweck selbst bestimmt.

Für diese Verarbeitungen muss WUXUAI eine eigene Rechtsgrundlage und eigene Datenschutzinformation bereitstellen.

C. Keine pauschale gemeinsame Verantwortlichkeit

Eine gemeinsame Verantwortlichkeit zwischen WUXUAI und Restaurant soll nicht pauschal angenommen werden.

Sie ist nur dann gesondert zu prüfen, wenn beide Parteien gemeinsam die Zwecke und wesentlichen Mittel einer konkreten Verarbeitung festlegen.

Sollte eine Verarbeitung als gemeinsame Verantwortlichkeit einzustufen sein, ist hierfür vor Aktivierung eine gesonderte Vereinbarung über die gemeinsame Verantwortlichkeit abzuschließen.

3.2 Restaurantunternehmen

Vertragliche Rolle

Das Restaurantunternehmen ist Vertragspartner von WUXUAI.

Als Restaurantunternehmen gilt die natürliche oder juristische Person, die:

- den Restaurantbetrieb führt;
- das Bonusprogramm wirtschaftlich verantwortet;
- Rewards bereitstellt;
- die Bedingungen des Bonusprogramms festlegt;
- Mitarbeiter und Filialen verwaltet;
- gegenüber Gästen als Anbieter des Bonusprogramms auftritt.

Datenschutzrechtliche Rolle

Das Restaurant ist grundsätzlich Verantwortlicher für die Verarbeitung personenbezogener Daten der Gäste innerhalb seines Bonusprogramms.

Das Restaurant entscheidet insbesondere über:

- Zweck des Bonusprogramms;
- Zielgruppe;
- Teilnahmebedingungen;
- Art und Umfang der erhobenen Gastdaten;
- Punkte- und Rewardregeln;
- Speicherdauer;
- Marketingkommunikation;
- Programmänderung und Programmbeendigung;
- Behandlung von Datenschutzanfragen;
- Auswahl und Nutzung optionaler Kommunikationskanäle.

Pflichten des Restaurants

Das Restaurant ist verpflichtet:

- nur rechtmäßige Bonusprogramme zu betreiben;
- vollständige und richtige Unternehmensdaten anzugeben;
- gültige Teilnahmebedingungen zu veröffentlichen;
- eine passende Datenschutzerklärung bereitzustellen;
- zulässige Rechtsgrundlagen festzulegen;
- erforderliche Einwilligungen einzuholen;
- Werbenachrichten nur bei bestehender Berechtigung zu versenden;
- Betroffenenrechte fristgerecht zu bearbeiten;
- nur berechtigten Mitarbeitern Zugang zu gewähren;
- Zugänge unverzüglich zu sperren, wenn Mitarbeiter ausscheiden;
- Mitarbeiter auf das Datengeheimnis zu verpflichten;
- keine rechtswidrigen, diskriminierenden oder irreführenden Rewards anzubieten;
- Punkte- und Rewardänderungen transparent umzusetzen;
- Beschwerden über Leistungen und Rewards selbst zu bearbeiten;

- WUXUAI bei Datenschutz- und Sicherheitsprüfungen zu unterstützen.
-

3.3 Restaurant-Owner

Rolle

Der Restaurant-Owner ist die höchstberechtigte natürliche Person innerhalb eines Restaurantkontos.

Der Owner handelt im Namen des Restaurantunternehmens.

Berechtigungen

Der Owner darf insbesondere:

- Unternehmens- und Restaurantdaten verwalten;
- Filialen anlegen;
- Benutzer einladen;
- Rollen vergeben;
- Bonusprogramme konfigurieren;
- Punkte- und Rewardregeln festlegen;
- Rewards erstellen und deaktivieren;
- Rechtstexte verwalten;
- Marketingkanäle aktivieren oder deaktivieren;
- Datenschutzanfragen bearbeiten;
- Exporte anfordern;
- Audit-Protokolle einsehen;
- Vertrags- und Abrechnungsdaten einsehen;
- das Restaurantprogramm pausieren;
- eine Programmbeendigung beantragen.

Einschränkungen

Der Owner darf nicht:

- Daten anderer Restaurantunternehmen einsehen;
- globale WUXUAI-Systemdaten verändern;
- historische Audit-Einträge löschen;
- fremde Gastkonten außerhalb des eigenen Restaurantkontexts öffnen;
- Sicherheits- oder RLS-Regeln umgehen;
- dokumentierte Einwilligungen rückwirkend verändern;
- Legal-Acceptance-Nachweise überschreiben;
- bereits erfolgte Reward-Einlösungen unprotokolliert löschen.

Verantwortlichkeit

Handlungen eines berechtigten Owners werden dem Restaurantunternehmen zugerechnet.

Das Restaurantunternehmen ist verantwortlich dafür, dass nur vertretungsbefugte oder ausreichend bevollmächtigte Personen die Owner-Rolle erhalten.

3.4 Filialadministrator oder Filialleiter

Rolle

Der Filialadministrator verwaltet ausschließlich eine oder mehrere ihm zugewiesene Filialen.

Er besitzt keine unternehmensweite Vollmacht, soweit diese nicht ausdrücklich erteilt wurde.

Zulässige Berechtigungen

Der Filialadministrator darf je nach Freigabe:

- Filialdaten verwalten;
- Mitarbeiter der Filiale einladen oder sperren;
- Tages-PINs einsehen;
- Punktebuchungen der Filiale prüfen;
- Reward-Einlösungen der Filiale prüfen;
- operative Statistiken einsehen;
- Supportfälle der Filiale melden;
- lokale QR-Codes verwalten;
- lokale Rewards aktivieren, sofern der Owner dies freigibt.

Unzulässige Berechtigungen

Der Filialadministrator darf grundsätzlich nicht:

- den SaaS-Vertrag ändern;
- Rechnungs- oder Zahlungsdaten ändern;
- Rechtstexte unternehmensweit freigeben;
- andere Filialen einsehen;
- globale Rollen vergeben;
- das gesamte Bonusprogramm beenden;
- Datenschutzexporte ohne entsprechende Zusatzberechtigung abrufen;
- Massendatenexporte durchführen;
- Unternehmens-Owner entfernen.

3.5 Restaurantmitarbeiter

Rolle

Restaurantmitarbeiter verwenden die Plattform ausschließlich zur operativen Abwicklung des Bonusprogramms.

Zulässige Funktionen

Mitarbeiter dürfen abhängig von ihrer Rolle:

- die aktuelle Tages-PIN einsehen;
- Punktebuchungen bestätigen;

- Reward-Einlösungen bestätigen;
- Einlösecodes prüfen;
- Fehlermeldungen zum Vorgang sehen;
- den Status einer konkreten Transaktion prüfen;
- einen Supportfall melden.

Datenminimierung

Mitarbeiter sollen nur jene Gastdaten sehen, die für den konkreten Vorgang erforderlich sind.

Grundsätzlich nicht sichtbar sein sollen:

- vollständige Gastprofile ohne operativen Bedarf;
- Marketingeinwilligungen;
- Datenschutzanfragen;
- Exportdateien;
- vollständige Besuchshistorien;
- interne Supportnotizen;
- Zahlungs- oder Vertragsdaten;
- Daten anderer Filialen.

Pflichten

Mitarbeiter sind verpflichtet:

- Zugangsdaten geheim zu halten;
- Tages-PINs nicht an Gäste weiterzugeben;
- keine Screenshots von Gastdaten anzufertigen;
- keine personenbezogenen Daten privat zu speichern;
- nur tatsächliche Transaktionen zu bestätigen;
- Manipulationsversuche zu melden;
- den Zugang nicht gemeinsam mit anderen Personen zu nutzen;
- Datenschutz- und Sicherheitsanweisungen des Arbeitgebers einzuhalten.

Personenbezogene Daten, die Mitarbeitern aufgrund ihrer Tätigkeit zugänglich werden, sind vertraulich zu behandeln. Mitarbeiter dürfen solche Daten nur aufgrund zulässiger Anordnungen verwenden oder weitergeben. Die Pflicht zur Geheimhaltung soll auch nach Ende der Tätigkeit fortbestehen.

3.6 Plattformadministrator von WUXUAI

Rolle

Der Plattformadministrator ist eine besonders privilegierte interne Rolle von WUXUAI.

Diese Rolle darf nur einer begrenzten Anzahl ausdrücklich autorisierter Personen zugewiesen werden.

Zulässige Zwecke des Zugriffs

Ein Plattformadministrator darf auf Kundendaten nur zugreifen, soweit dies erforderlich ist für:

- technischen Support;
- Sicherheitsuntersuchungen;
- Fehlerbehebung;
- Missbrauchsprüfung;
- Wiederherstellung;
- Durchführung dokumentierter Restaurantanweisungen;
- Erfüllung rechtlicher Verpflichtungen;
- Abwehr oder Durchsetzung rechtlicher Ansprüche.

Verbotene Zugriffe

Unzulässig sind insbesondere:

- neugierbasierte Zugriffe;
- private Nutzung von Gastdaten;
- nicht dokumentierte Datenänderungen;
- unprotokolierte Punkte- oder Rewardkorrekturen;
- Export von Daten ohne konkreten Zweck;
- Nutzung von Gastdaten für eigene Werbung;
- Weitergabe an unberechtigte Dritte.

Sicherheitsanforderungen

Für Plattformadministratoren gelten mindestens:

- individuelle Benutzerkonten;
- verpflichtende Mehrfaktor-Authentifizierung;
- rollenbasierte Minimalberechtigungen;
- vollständige Audit-Protokollierung;
- dokumentierter Zugriffsgrund;
- regelmäßige Rechteüberprüfung;
- unverzügliche Sperrung beim Ausscheiden;
- Vertraulichkeits- und Datenschutzverpflichtung;
- Trennung von Staging und Production;
- kein gemeinsames Administratorkonto.

3.7 WUXUAI-Supportmitarbeiter

Rolle

Supportmitarbeiter unterstützen Restaurants und Nutzer bei Bedienungs- und technischen Problemen.

Standardzugriff

Supportmitarbeiter erhalten grundsätzlich keinen vollständigen Datenbankzugriff.

Sie dürfen nur:

- Restaurantstammdaten in notwendigem Umfang sehen;
- Statusinformationen einsehen;
- technische Fehlercodes prüfen;
- Supportnotizen erstellen;
- betroffene Vorgänge anhand begrenzter IDs suchen;
- Fälle an privilegierte Administratoren eskalieren.

Erweiterter Zugriff

Ein zeitlich begrenzter erweiterter Zugriff darf nur erfolgen, wenn:

- ein konkreter Supportfall besteht;
 - der Zugriff erforderlich ist;
 - der Zugriff protokolliert wird;
 - der Umfang auf das notwendige Minimum beschränkt bleibt;
 - sensible Aktionen zusätzlich bestätigt werden.
-

3.8 Gast oder Programmteilnehmer

Rolle

Der Gast ist Teilnehmer eines konkreten Bonusprogramms eines konkreten Restaurants.

Es entsteht kein restaurantübergreifender einheitlicher Punkteanspruch.

Rechte des Gastes

Der Gast kann insbesondere:

- am Bonusprogramm teilnehmen;
- seinen Punktestand einsehen;
- verfügbare Rewards einsehen;
- Rewards nach den geltenden Bedingungen einlösen;
- seine Teilnahmebedingungen einsehen;
- seine Datenschutzinformationen einsehen;
- freiwillige Marketingeinwilligungen erteilen oder widerrufen;
- Auskunft oder Datenexport beantragen;
- Berichtigung verlangen;
- Löschung beantragen, soweit keine Aufbewahrungspflichten entgegenstehen;
- sich beim Restaurant oder bei der zuständigen Datenschutzbehörde beschweren.

Pflichten des Gastes

Der Gast darf:

- nur ein ihm zugeordnetes Konto verwenden;
- keine Punktebuchungen manipulieren;
- keine Tages-PINs oder Einlösecodes missbräuchlich beschaffen;

- Rewards nicht mehrfach einlösen;
- keine automatisierten Angriffe durchführen;
- keine falschen Angaben zur Erlangung von Vorteilen machen;
- QR-Codes, Tokens oder Zugangsdaten nicht missbräuchlich verbreiten.

Keine Übertragbarkeit

Punkte, Rewards und Mitgliedschaften sind grundsätzlich:

- restaurantbezogen;
- personenbezogen;
- nicht übertragbar;
- nicht auszahlbar;
- nicht als Geldwert geschuldet.

Abweichungen dürfen nur durch ausdrücklich veröffentlichte Restaurantbedingungen vorgesehen werden.

3.9 Anonymer Besucher

Ein anonymer Besucher darf nur auf Daten zugreifen, die ausdrücklich öffentlich bestimmt sind.

Dazu gehören je nach Konfiguration:

- Restaurantname;
- Restaurantlogo;
- öffentliches Bonusangebot;
- veröffentlichte Rewards;
- öffentliche Teilnahmebedingungen;
- öffentliche Datenschutzerklärung;
- Impressum;
- Kontaktinformationen;
- öffentlich freigegebene Restaurantstandorte.

Nicht öffentlich sind insbesondere:

- Gastdaten;
 - Punktestände;
 - Rewardcodes;
 - Tages-PINs;
 - Consent-Daten;
 - Audit-Daten;
 - Mitarbeiterdaten;
 - interne Restaurantdaten;
 - Supportnotizen;
 - Datenschutzanfragen.
-

4. Technische Systemrollen

4.1 Public Client

Der Public Client darf ausschließlich freigegebene öffentliche RPCs verwenden.

Jeder öffentliche RPC muss:

- Eingaben validieren;
 - Restaurantkontext eindeutig prüfen;
 - Daten auf das notwendige Minimum beschränken;
 - Rate Limits beachten;
 - keine internen Tabellen vollständig offenlegen;
 - keine Service-Role-Rechte an den Client weitergeben.
-

4.2 Authenticated Customer Client

Der authentifizierte Gast darf nur:

- eigene Daten;
- restaurantbezogene eigene Punkte;
- eigene Rewardansprüche;
- eigene Einlösungen;
- eigene Consents;
- eigene Legal-Acceptances;
- eigene Datenschutzanfragen

einsehen oder bearbeiten.

4.3 Restaurant Client

Der Restaurant-Client darf nur Daten des zugeordneten Restaurants beziehungsweise der freigegebenen Filiale verarbeiten.

Die Berechtigung darf nicht allein aus einer im Browser gespeicherten Restaurant-ID abgeleitet werden.

Die serverseitige Prüfung muss anhand einer vertrauenswürdigen Mitgliedschafts- und Rollenbeziehung erfolgen.

4.4 Service Role

Die technische Service Role darf niemals im Browser, in öffentlich ausgeliefertem JavaScript oder in zugänglichen Client-Konfigurationen enthalten sein.

Sie darf nur in kontrollierten serverseitigen Funktionen verwendet werden.

Jeder Service-Role-Vorgang muss:

- einen definierten Zweck haben;
 - auf notwendige Daten begrenzt sein;
 - Eingaben validieren;
 - den Restaurantkontext prüfen;
 - nach Möglichkeit auditierbar sein.
-

4.5 Scheduler und Hintergrundprozesse

Automatisierte Prozesse können insbesondere ausführen:

- Punkteverfallsprüfung;
- Rewardablaufprüfung;
- Geburtstagsreward-Erstellung;
- Reminder-Vorbereitung;
- Consent-Prüfung vor Nachrichtenzustellung;
- Program-Ende-Workflows;
- Datenlöschungen nach Freigabe;
- technische Health Checks.

Automatisierte Prozesse dürfen keine Marketingnachricht versenden, wenn der hierfür erforderliche gültige Consent nicht vorliegt.

5. Auftragsverarbeiter und Unterauftragsverarbeiter

5.1 WUXUAI als erster Auftragsverarbeiter

Soweit WUXUAI im Auftrag eines Restaurants personenbezogene Gastdaten verarbeitet, muss zwischen Restaurant und WUXUAI ein Auftragsverarbeitungsvertrag abgeschlossen werden.

WUXUAI darf weitere Auftragsverarbeiter nur nach Maßgabe dieses Vertrags einsetzen.

5.2 Vorgesehene Unterauftragsverarbeiter

Vorläufig vorgesehen sind:

- Supabase für Datenbank-, Authentifizierungs- und Backenddienste;
- Cloudflare für Hosting-, Netzwerk-, Sicherheits- und Edge-Dienste;
- Stripe für Zahlungs- und Abrechnungsdienste;
- ein noch auszuwählender E-Mail-Dienst;
- gegebenenfalls ein SMS-Dienst;
- gegebenenfalls ein Push-Dienst;
- gegebenenfalls ein Fehlertracking- und Monitoring-Dienst.

Für jeden Unterauftragsverarbeiter sind zu dokumentieren:

- vollständiger Firmenname;
- Sitz;
- Leistungszweck;
- Datenkategorien;
- betroffene Personengruppen;
- Verarbeitungsstandorte;
- Drittlandbezug;
- Rechtsgrundlage des Transfers;
- technische und organisatorische Maßnahmen;
- Datum der Aufnahme;
- Datum der Information der Restaurants.

WUXUAI soll nur Dienstleister einsetzen, die hinreichende Garantien für geeignete technische und organisatorische Maßnahmen bieten. Verträge zur Auftragsverarbeitung müssen schriftlich oder elektronisch dokumentiert werden.

6. Verantwortungsmatrix

Tätigkeit	WUXUAI	Restaurant	Owner	Mitarbeiter	Gast
SaaS-Betrieb	verantwortlich	Nutzer	–	–	–
Bonusprogramm festlegen	technisch unterstützend	verantwortlich	handelnd	–	Teilnehmer
Punkte vergeben	technische Verarbeitung	verantwortlich	konfiguriert	operativ bestätigt	erhält
Rewards bereitstellen	keine Leistungspflicht	verantwortlich	konfiguriert	löst ein	beansprucht
Gastdatenschutzinformation	Vorlage/ Technik	verantwortlich	veröffentlicht	–	erhält
SaaS-Datenschutz	verantwortlich	betroffen	betroffen	betroffen	teilweise betroffen
Marketingzweck	technische Unterstützung	verantwortlich	konfiguriert	–	willigt ein
Consent speichern	technische Verarbeitung	verantwortlich	überprüft	kein Zugriff	erteilt/ widerruft
Sicherheitsbetrieb	verantwortlich für Plattform	verantwortlich für eigene Zugänge	verwaltet Rollen	schützt Zugang	schützt Token
Betroffenen-anfrage	technische Unterstützung	verantwortlich	bearbeitet	kein Zugriff	stellt Antrag

Tätigkeit	WUXUAI	Restaurant	Owner	Mitarbeiter	Gast
Datenexport	technische Bereitstellung	Freigabe/ Verantwortung	löst aus	kein Zugriff	erhält
Löschung	technische Ausführung	Entscheidung	genehmigt	kein Zugriff	beantragt
Restaurant-Rechtstexte	Vorlage/ Versionierung	inhaltlich verantwortlich	veröffentlicht	–	akzeptiert
SaaS-Vertrag	verantwortlich	Vertragspartner	vertritt Restaurant	–	–
Abrechnung	verantwortlich	zahlungspflichtig	verwaltet	–	–
Audit-Logs	technisch verantwortlich	berechtigter Nutzer	kontrolliert	wird protokolliert	wird teilweise protokolliert

7. Haftungs- und Leistungsabgrenzung

7.1 Verantwortungsbereich WUXUAI

WUXUAI verantwortet im Rahmen des Vertrags insbesondere:

- vertragsgemäße Bereitstellung der Plattform;
- technische Sicherheitsmaßnahmen;
- korrekte Mandantentrennung;
- vertragsgemäße Verarbeitung;
- technische Protokollierung;
- vereinbarte Backup- und Wiederherstellungsmaßnahmen;
- ordnungsgemäße Verwaltung eigener Dienstleister;
- Unterstützung bei Datenschutzanfragen;
- Schutz eigener Administrationszugänge.

7.2 Verantwortungsbereich Restaurant

Das Restaurant verantwortet insbesondere:

- Rechtmäßigkeit des Bonusprogramms;
- Richtigkeit der Restaurantangaben;
- Inhalt und Erfüllbarkeit der Rewards;
- Preis- und Rabattangaben;
- steuerliche Behandlung seiner Leistungen;
- Rechtmäßigkeit seiner Werbekommunikation;
- Auswahl der Empfänger;
- Rechtmäßigkeit der eingegebenen Daten;
- Berechtigungsvergabe an Mitarbeiter;
- Einhaltung arbeitsrechtlicher Vorgaben;

- Behandlung gastronomischer Beschwerden;
- Einlösung und tatsächliche Gewährung von Rewards.

7.3 Keine Haftungsverlagerung durch Plattformfunktion

Eine technische Einstellung, Vorlage, Standardeinstellung oder Empfehlung von WUXUAI ersetzt keine rechtliche, steuerliche oder betriebliche Prüfung durch das Restaurant.

Die technische Möglichkeit, eine Funktion zu aktivieren, bedeutet nicht automatisch, dass deren Nutzung im konkreten Einzelfall rechtlich zulässig ist.

8. Eskalations- und Meldewege

8.1 Technischer Vorfall

Restaurant oder Mitarbeiter meldet den Vorfall an WUXUAI Support.

WUXUAI:

- klassifiziert den Vorfall;
- dokumentiert Zeitpunkt und Umfang;
- sichert relevante Logs;
- begrenzt den Schaden;
- informiert das Restaurant;
- führt erforderliche technische Maßnahmen aus.

8.2 Mögliche Datenschutzverletzung

WUXUAI informiert das betroffene Restaurant unverzüglich, sobald WUXUAI von einer möglichen Verletzung personenbezogener Daten Kenntnis erhält, soweit das Restaurant hierfür Verantwortlicher ist.

Das Restaurant entscheidet als Verantwortlicher über:

- Risikobewertung;
- Meldung an die Datenschutzbehörde;
- Benachrichtigung betroffener Personen;
- weitere rechtliche Maßnahmen.

WUXUAI stellt hierfür verfügbare technische Informationen bereit.

8.3 Missbrauch durch Mitarbeiter

Das Restaurant ist verpflichtet:

- Zugang unverzüglich zu sperren;
- Beweise zu sichern;
- WUXUAI bei technischem Missbrauch zu informieren;

- arbeits- und datenschutzrechtliche Maßnahmen zu prüfen.

8.4 Unzulässiger Plattformadministratorzugriff

WUXUAI muss:

- Zugriff unverzüglich untersuchen;
- Zugang sperren;
- Audit-Protokolle sichern;
- betroffene Restaurants informieren, soweit erforderlich;
- Meldepflichten prüfen;
- Korrekturmaßnahmen dokumentieren.

9. Rollenfreigabe und regelmäßige Kontrolle

Für alle privilegierten Rollen gilt:

- Berechtigung nur nach dokumentierter Freigabe;
- Vergabe nach dem Need-to-know-Prinzip;
- regelmäßige Überprüfung;
- sofortige Sperrung bei Rollenwechsel oder Ausscheiden;
- keine gemeinsamen Konten;
- keine dauerhaften Notfallzugänge;
- kritische Aktionen werden protokolliert;
- Rollen dürfen sich nicht selbst unbegrenzt erweitern.

Mindestens halbjährlich soll eine Berechtigungsprüfung erfolgen.

Bei sicherheitskritischen Rollen soll zusätzlich eine sofortige Prüfung bei jeder personellen oder organisatorischen Änderung erfolgen.

10. Verbindliche technische Folgerungen

Aus diesem Rollenmodell ergeben sich für die spätere Codex-Implementierung mindestens folgende Anforderungen:

1. Eine zentrale, serverseitig geprüfte Rollenquelle.
2. Strikte Tenant-Isolation über Restaurantmitgliedschaften.
3. Filial-Scope zusätzlich zum Restaurant-Scope.
4. Keine Autorisierung ausschließlich über Local Storage oder URL-Parameter.
5. Separate Rollen für Owner, Filialadmin, Staff, Support und Plattformadmin.
6. Audit-Log für alle privilegierten Aktionen.
7. Pflichtfeld für Zugriffsgrund bei Supportzugriffen.
8. Kein direktes Bearbeiten historischer Consents.
9. Kein direktes Löschen historischer Legal-Acceptances.
10. Keine Punkte- oder Rewardkorrektur ohne Gegenbuchung und Begründung.
11. Datenschutzexporte nur nach starker Berechtigungsprüfung.

12. Service Role ausschließlich serverseitig.
 13. Mehrfaktor-Authentifizierung für Plattformadministratoren.
 14. Regelmäßige Berechtigungsreviews.
 15. Automatische Sperrung deaktivierter Mitarbeiter.
 16. Keine restaurantübergreifenden Gastdaten für Restaurantrollen.
 17. Read-only-Zugriff auf veröffentlichte Rechtstexte für anonyme Gäste.
 18. Separate Verantwortungskennzeichnung pro Datenverarbeitung.
 19. Unterauftragsverarbeiterregister mit Versions- und Änderungsnachweis.
 20. Datenschutz- und Sicherheitsvorfälle mit dokumentiertem Workflow.
-

11. Noch anwaltlich zu klärende Punkte

Die folgenden Punkte sind ausdrücklich dem österreichischen Rechtsanwalt vorzulegen:

1. Ob einzelne Plattform-Sicherheits- und Missbrauchsverarbeitungen ausschließlich WUXUAI als Verantwortlichem zuzuordnen sind.
 2. Ob bestimmte Analytics- oder Recommendation-Funktionen eine gemeinsame Verantwortlichkeit auslösen könnten.
 3. Ob WUXUAI für einzelne Kommunikationsprozesse als eigenständig Verantwortlicher oder Auftragsverarbeiter handelt.
 4. Welche konkrete Haftungsbegrenzung im österreichischen B2B-Verhältnis zulässig und wirtschaftlich sinnvoll ist.
 5. Welche Verantwortlichkeit bei vorgegebenen Standard-Templates besteht.
 6. Ob ein Datenschutzbeauftragter verpflichtend oder freiwillig sinnvoll ist.
 7. Welche Drittlandtransfermechanismen für eingesetzte Anbieter notwendig sind.
 8. Welche Pflichten bei einer späteren internationalen Expansion entstehen.
 9. Welche gesetzlichen Aufbewahrungsfristen für einzelne Audit-, Vertrags- und Abrechnungsdaten gelten.
 10. Ob für besondere Supportzugriffe eine zusätzliche Vereinbarung oder Einwilligung erforderlich ist.
-

12. Freigabestatus

Fachlicher Entwurfsstatus: abgeschlossen

Technische Umsetzung: noch nicht beauftragt

Anwaltliche Prüfung: ausstehend

Steuerliche Prüfung: ausstehend

Produktive Rechtsfreigabe: nicht erteilt

Dieses Dokument darf vor anwaltlicher Prüfung nicht als endgültige rechtliche Bewertung oder als bestätigte Rechtskonformität der WUXUAI-Plattform bezeichnet werden.